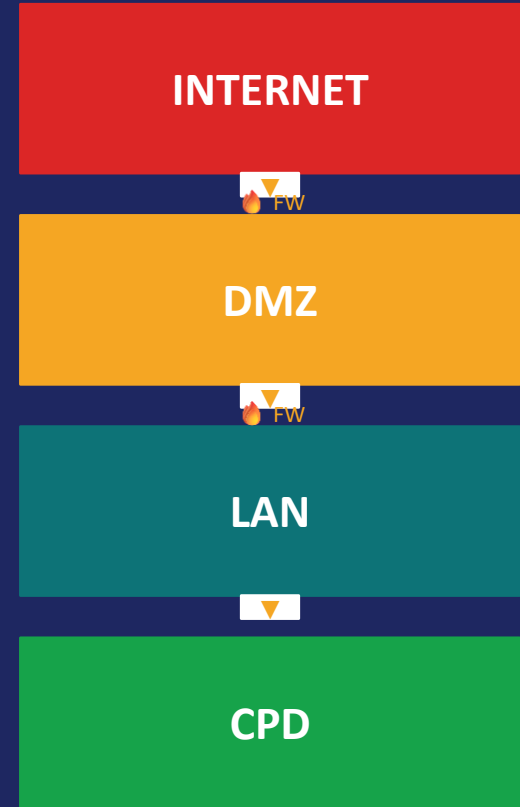


UD5: Cortafuegos y Segmentación de Red

Bloque 9 | 15 horas

Marco normativo: RD 311/2022 ENS Anexo II · CCN-STIC 408/811 · NIST SP 800-41

Lab SOC: OPNsense (VM 100) · Suricata IDS/IPS · vmbr0/vmbr1/vmbr2 · WireGuard VPN



Contenidos de la Unidad

01

Tipos de cortafuegos

Por ubicación, funcionalidad y capa OSI. Hardware vs software

02

Segmentación de red y DMZ

Zonas de seguridad, VLAN, microsegmentación, arquitecturas de referencia

03

Reglas de filtrado y ACLs

Sintaxis, orden de evaluación, mejores prácticas, pruebas

04

VPN y canales seguros

IPSec, SSL/TLS, WireGuard, Zero Trust. Lab: OPNsense WireGuard

05

Auditoría y monitorización del cortafuegos

Logs, KPIs, pruebas y mejora continua

01

Tipos de Cortafuegos

Bloque 9 · Por capa OSI, ubicación, hardware/software. OPNsense lab

Por capa OSI / funcionalidad

Filtrado de paquetes (L3/L4): Inspecciona cabeceras IP/TCP/UDP. Stateless. Rápido pero sin contexto de sesión.

Stateful Inspection (L4): Mantiene tabla de estados de conexión. Detecta paquetes fuera de secuencia.

Proxy / Application FW (L7): Inspección profunda de protocolos de aplicación (HTTP, DNS, SMTP). WAF.

NGFW (Next-Generation FW): L7 + IDS/IPS integrado + App-ID + User-ID + SSL inspection + threat intel.

Hardware vs Software

Appliance hardware: Dispositivo dedicado: Cisco ASA/FTD, Fortinet FortiGate, Palo Alto PA. Rendimiento predecible.

Software / Virtual FW: VM sobre hipervisor: OPNsense, pfSense, VyOS, Cisco CSR. Flexible y económico.

Integrado en SO: iptables/nftables (Linux), Windows Defender Firewall, pf (BSD/macOS).

SD-WAN / SD-FW: Firewall definido por software integrado en soluciones SD-WAN. Palo Alto Prisma.

Por ubicación

Perimetral (Edge FW): Entre Internet y red interna. Primera línea de defensa. Gestiona DMZ.

Interno / Segmentación: Entre segmentos de red interna. Controla movimiento lateral.

Host-based FW: Software en el propio endpoint. Windows Defender FW, iptables, nftables, ufw.

Cloud FW / FWaaS: Firewall como servicio en la nube. Azure Firewall, AWS Network FW, Cloudflare Gateway.

OPNsense en el laboratorio

VM 100 — Proxmox (Dell R620): 3 interfaces: WAN (vmbr0/192.168.0.160), LAN (vmbr1/192.168.99.1), DMZ (vmbr2/10.1.99.1).

Suricata IDS/IPS integrado: Inspección en interfaces LAN y DMZ. Reglas ET Open + custom. Alertas a Security Onion.

Plugin os-wireguard: VPN WireGuard para acceso remoto. Integrada con sistema de usuarios OPNsense.

HAProxy + Let's Encrypt: Reverse proxy con terminación TLS para servicios expuestos del lab.

02

Segmentación y DMZ

Bloque 9 · Zonas de seguridad, arquitectura lab SOC

Arquitectura de red del laboratorio SOC (referencia real)

INTERNET / WAN — 192.168.0.0/24 (vmbr0 · Management)

🔥 OPNsense VM 100 🔥

LAN — 192.168.99.0/24 (vmbr1)
GW: 192.168.99.1

DMZ — 10.1.99.0/24 (vmbr2)
GW: 10.1.99.1

VM 200
Wazuh · 192.168.99.20

VM 110
TheHive · 192.168.99.30

VM 112
QRadar CE · 192.168.99.40

VM 102
Ollama LLM · 192.168.0.102

VM 101
Security Onion · 10.1.99.2

VM 108
DC01 / Sysmon · 10.1.99.60

VM 107
ubuntu-moderna · 10.1.99.50

VM 501
Guacamole · 10.1.99.x

Principios de diseño de la DMZ

- ▶ Servicios públicos en DMZ, nunca en LAN directamente
- ▶ DMZ no puede iniciar conexiones a LAN (flujo unidireccional)
- ▶ Tráfico LAN → DMZ: solo puertos y protocolos estrictamente necesarios
- ▶ Tráfico Internet → DMZ: solo servicios publicados (80/443)

03

Reglas de Filtrado y Suricata IDS/IPS

Bloque 9 · ACLs, sintaxis Suricata, reglas ET Open

Las reglas de un cortafuegos se evalúan en orden secuencial (top-down). La primera regla que coincide con el tráfico se aplica y el procesamiento se detiene. La regla implícita final siempre es DENY ALL.

Ejemplo de política de firewall — OPNsense (laboratorio)

#	Acción	Prot o	Origen	Destino	Puerto dst	Descripción
1	✓ PASS	TCP	LAN_NET	WAN	80,443	Navegación web desde LAN
2	✓ PASS	UDP	LAN_NET	WAN	53	DNS hacia resolvers externos
3	✓ PASS	TCP	LAN_NET	DMZ_NET	any	LAN accede a servicios DMZ
4	✓ PASS	TCP	WAN	DMZ:10.1.99.2	443	HTTPS a Security Onion (soc.juanprofesor.com)
5	✓ PASS	TCP	WAN	VM501_Guacamole	443	Acceso remoto vía Guacamole
6	✗ BLOCK	any	DMZ_NET	LAN_NET	any	DMZ no puede alcanzar LAN
7	✗ BLOCK	TCP	any	any	23,21	Bloquear Telnet y FTP

Mejores prácticas en la definición de reglas

Default Deny All: toda política comienza con denegación implícita; solo se permite lo explícitamente necesario.

Mínimo privilegio: las reglas PASS deben ser lo más específicas posible (IP, puerto, protocolo, dirección).

Orden importa: las reglas más específicas van primero; las generales al final.

Suricata es el motor IDS/IPS de código abierto integrado en OPNsense (VM 100) y Security Onion (VM 101). Analiza el tráfico en tiempo real comparando contra firmas y reglas de comportamiento.

Modos de operación

IDS (Intrusion Detection System)

Modo pasivo. Solo genera alertas. Sin interferencia en el tráfico. Recibe tráfico duplicado (mirroring/tap).

IPS (Intrusion Prevention System)

Modo inline (en línea). Puede bloquear, descartar o resetear conexiones maliciosas en tiempo real.

NSM (Network Security Monitor)

Análisis completo de protocolos de red. En Security Onion con Zeek + Suricata para visibilidad total.

Anatomía de una regla Suricata

```
alert
tcp
$EXTERNAL_NET any
$HOME_NET 22
(msg:"SSH Scan"; flow:to_server;
```

Acción

Proto

Src/Dst

Opciones

MF0486_3 · UD5 · Cortafuegos y Segmentación de Red

Fuentes de reglas y configuración en lab

ET Open (Emerging Threats)

Conjunto gratuito y activo. +40.000 reglas. Actualización diaria. Categorías: malware, exploit, scan, policy.

ET Pro

Versión comercial con reglas 0-day y detección avanzada de amenazas. Licencia por sensor.

Suricata-Update

Herramienta oficial de gestión de reglas. Agrega múltiples fuentes: ET, Abuse.ch, PTRD.

Reglas custom (lab)

Reglas específicas para el lab: detección de técnicas Atomic Red Team, tráfico de herramientas de pentesting.

04

VPN y Canales Seguros

Bloque 9 · IPSec, OpenVPN, WireGuard, Zero Trust

Una VPN (Virtual Private Network) establece un canal cifrado sobre una red no confiable (Internet), permitiendo comunicaciones seguras entre sedes, usuarios remotos y servicios en la nube.

IPSec/IKEv2

- ▶ Estándar IETF. Capas 3-4 del modelo OSI.
- ▶ Modos: Tunnel (site-to-site) y Transport (host-to-host).
- ▶ IKEv2: negociación de claves más rápida y robusta que IKEv1.
- ▶ Autenticación: certificados X.509, PSK, EAP.
- ▶ Cifrado: AES-256-GCM + HMAC-SHA-256/384.
- ▶ Ideal para conexiones site-to-site entre sedes.

SSL/TLS (OpenVPN)

- ▶ Túnel sobre TLS. Puerto 1194/UDP o 443/TCP.
- ▶ Fácil de atravesar NAT y firewalls restrictivos.
- ▶ Cliente disponible en todas las plataformas.
- ▶ Autenticación: certificados + usuario/contraseña + MFA.
- ▶ Rendimiento inferior a WireGuard en hardware moderno.
- ▶ Ampliamente desplegado en entornos empresariales.

WireGuard

- ▶ Protocolo moderno (~4.000 líneas de código vs ~400.000 IPSec).
- ▶ ChaCha20 + Poly1305 + Curve25519 + BLAKE2s.
- ▶ Rendimiento superior: menor latencia, más throughput.
- ▶ Stateless: ideal para dispositivos móviles (roaming).
- ▶ Integrado en kernel Linux desde 5.6. Plugin OPNsense.
- ▶ Laboratorio: os-wireguard en VM 100 para acceso remoto.

Zero Trust Network Access (ZTNA): «Nunca confiar, siempre verificar». Acceso basado en identidad + postura del dispositivo + contexto (ubicación, hora, riesgo). Sin VPN tradicional: acceso solo al recurso específico. Cloudflare Access, Zscaler ZPA, Microsoft Entra ID + Conditional Access.

05

Auditoría y Monitorización

Bloque 9 · Logs, KPIs, plan de pruebas

Los registros del cortafuegos son la fuente primaria de visibilidad sobre el tráfico de red. El ENS (control [op.mon.1]) y el RGPD (trazabilidad) exigen su existencia, integridad y disponibilidad durante un período adecuado.

Tipos de registros de auditoría en OPNsense

Firewall (filter.log)

Campos: Timestamp, interface, action (pass/block), protocol, src_ip:port, dst_ip:port, rule_id.

```
2026-05-20T14:32:11 block TCP 185.220.101.x:54231 → 10.1.99.2:22 [SSH brute force]
```

IDS/IPS (Suricata alerts)

Campos: Timestamp, signature_id, signature, category, severity (1-3), src/dst IP:port, proto.

```
ET SCAN Nmap SYN scan (TCP) - SID:2000537 - src 192.168.0.x - sev: medium
```

DHCP (dhcpd.log)

Campos: Timestamp, MAC address, IP asignada, hostname, lease time, renovación.

```
DHCPACK 192.168.99.45 to AA:BB:CC:DD:EE:FF (estudiante-pc) via vmbri
```

System / Auth (syslog)

Campos: Timestamp, facility, severity, hostname, process, message. RFC 5424.

```
May 20 14:30:05 opnsense sshd[1234]: Accepted publickey for admin from 192.168.0.x
```

KPIs y plan de pruebas

Tasa de falsos positivos

% alertas IDS que no son amenazas reales. Objetivo: <5%.

Reglas activas vs caducadas

Revisar trimestralmente. Eliminar reglas no usadas.

Tráfico bloqueado/día

Tendencia. Picos → posible ataque en curso.

Cobertura de puertos

% puertos expuestos con regla explícita (vs implícita).

Todo cortafuegos implantado debe someterse a un plan de pruebas documentado antes de entrar en producción y tras cada cambio significativo en las reglas.

1

Pruebas de conectividad permitida

Herramientas: *curl, wget, nmap -sT, ping, traceroute, netcat (nc), telnet.* | **Ejemplo:** *nmap -p 443 10.1.99.2 # Debe aparecer OPEN*

2

Pruebas de bloqueo de tráfico no autorizado

Herramientas: *nmap desde segmento no autorizado, hping3, Scapy.* | **Ejemplo:** *nmap -p 22 192.168.99.20 desde DMZ # Debe ser FILTERED*

3

Pruebas de detección IDS/IPS

Herramientas: *Atomic Red Team, Invoke-AtomicTest, nmap --script vuln, Metasploit (lab).* | **Ejemplo:** *Invoke-AtomicTest T1046 # Escaneo de red → debe generar alerta ET SCAN*

4

Pruebas de rendimiento y resistencia

Herramientas: *hping3 --flood, iperf3, ab (Apache Benchmark), wrk.* | **Ejemplo:** *hping3 -S --flood -p 80 10.1.99.2 # SYN flood controlado en lab*

5

Revisión de logs y alertas

Herramientas: *Security Onion (soc.juanprofesor.com), Kibana, Wazuh dashboard.* | **Ejemplo:** *Comprobar correlación: alerta Suricata → caso TheHive → log filter.log*

Resumen UD5

- 1 Los NGFW inspeccionan hasta capa 7 (aplicación) combinando firewall, IDS/IPS, App-ID y threat intelligence en un único dispositivo
- 2 La DMZ separa los servicios públicos de la LAN interna: DMZ nunca inicia conexiones a LAN, solo Internet → DMZ → LAN bajo control
- 3 Las reglas de firewall se evalúan top-down; la primera coincidencia se aplica; la política implícita final siempre es Deny All
- 4 Suricata en OPNsense opera en modo IDS (alertas) o IPS (bloqueo inline); las reglas ET Open se actualizan diariamente
- 5 WireGuard es el protocolo VPN moderno recomendado: menor superficie de código, cifrado moderno (ChaCha20/Poly1305), rendimiento superior
- 6 Los logs del firewall son la base de la trazabilidad; deben integrarse en el SIEM (Security Onion) y revisarse con KPIs definidos

MF0486_3

Seguridad en Equipos Informáticos

Módulo completado — 5 Unidades Didácticas · 90 horas

UD1	Fundamentos de Seguridad y Gestión del Riesgo	20h
UD2	Plan de Implantación y Protección de Datos	15h
UD3	Seguridad Física y Lógica de Sistemas	20h
UD4	Identificación y Bastionado de Sistemas	20h
UD5	Cortafuegos y Segmentación de Red	15h